

Incident 1 — Campagne de phishing ciblant la Direction Financière

Date/heure : courriel envoyé J1, 06:41:22 (+0100) / signalement SOC à 11:17

Source : Signal technique SOC + en-têtes Proofpoint (pièce A-11)

Analyse technique :

Les trois contrôles d'authentification ont échoué. Le SPF rejette l'adresse IP émettrice (193.42.55.108), car cette adresse n'est pas autorisée à envoyer des courriels au nom du domaine. Le DKIM est absent, ce qui signifie qu'aucune signature numérique n'atteste de l'authenticité du message. Le DMARC échoue également, confirmant que l'expéditeur n'est pas légitime. Le domaine utilisé, atlasgrid-it.info, imite délibérément notre domaine officiel, atlasgrid.ma. Il s'agit d'une technique de typosquatting, où un domaine similaire est utilisé pour tromper les utilisateurs. Le message a été envoyé via PHPMailer, un outil d'envoi de masse fréquemment utilisé dans les campagnes de phishing. Le contenu du courriel crée un sentiment d'urgence artificielle avec la mention « boîte suspendue ce soir », visant à pousser la victime à cliquer sur un lien qui ressemble à la page de connexion OWA. Une fois entré, l'utilisateur est incité à saisir ses identifiants sur une fausse page. Cette méthode correspond à la référence T1566.002 (Spearphishing Link) du référentiel MITRE ATT&CK. La cible visée était la Direction Financière. Bien que le message ait finalement été mis en quarantaine, cette mesure est intervenue trop tard. Au moins un utilisateur avait déjà saisi ses identifiants avant que le blocage ne soit effectif. Cette situation confirme une compromission réelle du compte.

Nom de l'incident	Campagne de phishing « Migration de messagerie »
Date	J1, 06:41 (envoi) / 11:17 (signalement)
vecteur	E-mail usurpé, lien de harvesting
impact	1 identifiant compromis (Direction Financière)
verdict	Preuve (échecs SPF/DKIM/DMARC + domaine usurpé)

Incident 2 — Vague de tickets support multi-services

Date/heure : J1, dès l'ouverture — signalement 11:32

Source : Signal technique SOC / support

Analyse technique :

1. Depuis l'ouverture, plusieurs symptômes concordants ont été rapportés par le support : lenteurs généralisées, coupures intermittentes des partages réseau, impressions bloquées et ralentissement des applications métier. Ces incidents touchent des postes répartis dans plusieurs services distincts (finance, RH, exploitation), ce qui exclut l'hypothèse d'une panne matérielle isolée sur une seule machine ou un seul département. À ce stade, aucune cause racine n'a été confirmée et le travail de corrélation entre les remontées est toujours en cours. Il est toutefois à noter, à titre de point de vigilance, que la nature de ces symptômes — notamment les coupures de partages réseau et les lenteurs disque/réseau — est compatible avec une activité d'écriture massive de fichiers, telle que celle observée dans l'Incident 3 (ransomware). Cette corrélation reste cependant une hypothèse à confirmer et non un fait établi à ce stade de l'analyse.

Nom de l'incident	Vague de tickets / dégradation de service multi-postes
Date	J1 Matin (11:32)
vecteur	inconnu a ce stad
impact	Perturbation opérationnelle transverse (finance, RH, exploitation)
verdict	En cours de qualification (corrélation possible avec Incident 3)

Incident 3 / Compromission ransomware sur le poste FIN-112

Date/heure : J-1, 03:12:09 → 03:15:22 (UTC)

Source : Journal Microsoft Defender for Endpoint, export CSV (pièce A-01)

Analyse technique (chronologie) :

L'analyse chronologique du poste FIN-112 révèle une compromission ransomware claire. À 03:12:09, Microsoft Defender détecte Ransom:Win32/Mirage.A (sévérité haute), mais la mise en quarantaine échoue ; le fichier en cause, `C:\Windows\svchost32.exe`, usurpe le nom d'un processus système légitime alors qu'il s'agit d'un binaire non signé, situé dans un emplacement suspect pour un exécutable tiers. À 03:13:55, un comportement d'écriture massive de fichiers est détecté, typique d'un chiffrement ransomware, accompagné d'une tentative de connexion sortante vers l'IP 45.137.184.62, censée être bloquée mais en réalité contournée — probablement à des fins de commande-et-contrôle ou d'exfiltration. À 03:14:31, la protection en temps réel est désactivée par le compte `admin_local` (technique T1562.001 du MITRE ATT&CK), une action intervenant après les deux alertes précédentes, ce qui suggère une réaction de l'attaquant pour poursuivre son action malgré la détection. L'export se termine à 03:15:22 avec six alertes au total. Par ailleurs, l'historique antérieur du poste RH-031 (J-42 et J-35) ne montre que des détections mineures

(PUA:Win32/Toolbar.Gen, sévérité basse, nettoyées automatiquement), sans lien apparent avec l'incident principal

Nom de l'incident	Compromission ransomware — poste FIN-112 (Ransom:Win32/Mirage.A)
Date	J-1, 03:12–03:15 (UTC)
vecteur	Binaire non signé déguisé en processus système, désactivation manuelle de l'EDR (compte admin local)
impact	Quarantaine échouée, tentative de C2 externe, protection désactivée
verdict	Preuve (T1562.001 confirmé, IOC : SHA256 partiel 3f9a4b1e9c2d7a5f0b8e6d41a97c...e0c71e, IP C2 45.137.184.62:443)

Incident 4 — Clé USB suspecte trouvée sur le parking visiteurs

Date/heure : signalement à 12:32 (jour de découverte : matin, non précisé en date absolue)

Source : Signal technique SOC / IT

Analyse technique :

Un employé a signalé le matin même avoir trouvé une clé USB sur le parking visiteurs, une zone accessible sans contrôle d'accès strict. Point essentiel : il n'a pas branché la clé sur son poste et l'a remise directement à l'IT, ce qui correspond exactement au bon réflexe à adopter face à ce type de découverte. Ce scénario est caractéristique d'une attaque par appât physique (USB drop attack), référencée sous la technique T1091 (Replication Through Removable Media) du MITRE ATT&CK, où un support amovible est volontairement déposé dans un lieu accessible pour inciter une victime à le connecter. À ce stade, aucune analyse technique n'a encore été réalisée : la clé va être examinée en environnement isolé afin d'en déterminer le contenu sans risquer de compromettre le réseau de production. Il ne s'agit donc pour l'instant que d'une hypothèse à vérifier, et non d'une preuve confirmée de malveillance.

Nom de l'incident Clé USB suspecte trouvée sur le parking visiteurs

Date Signalement à 12:32

Vecteur (potentiel)	Support amovible (USB drop attack)
Impact	Aucun à ce stade — clé non branchée, remise à l'IT
Verdict	En cours d'analyse (pièce A-19, environnement isolé) — non qualifiée preuve/fausse piste tant que l'analyse sandbox n'est pas faite

Incident 6 — Signalement d'un courriel « Migration Exchange » suspect

Date/heure : signalement à 15:22

Source : Signal technique SOC / détection

Analyse technique :

- Quatre utilisateurs ont signalé de manière indépendante un courriel intitulé « **Migration Exchange** » comme suspect — un signalement multiple et spontané par les utilisateurs est un bon indicateur de vigilance, mais ne constitue pas en soi une preuve technique.
- Le titre du courriel (« Migration Exchange ») est **thématiquement très proche** de celui de l'Incident 1 (« migration de messagerie »), ce qui interroge fortement sur un possible lien : rejeu de la même campagne, variante, ou nouvelle vague du même acteur.
- Le SOC adopte ici la bonne démarche méthodologique : **ne pas conclure au phishing avant vérification**, et procéder à l'analyse des en-têtes complets (émetteur, signatures SPF/DKIM/DMARC, domaine) disponibles en pièce **A-20**, exactement comme cela a été fait pour l'Incident 1.
- À ce stade, le signalement est **à qualifier** — aucun verdict (preuve / fausse piste / bruit) n'a encore été rendu, dans l'attente de l'analyse technique des en-têtes.

Incident 7 — Qualification du courriel « Migration Exchange » (pièce A-20)

Date/heure : courriel envoyé le J1 (horaire MTA interne 10.20.0.25) — signalement croisé à 15:22, analyse en-têtes reçue ensuite

Source : Signal technique SOC / détection + en-têtes Proofpoint (pièce A-20)

Conclusion technique : les trois contrôles d'authentification (SPF/DKIM/DMARC) passent tous, le domaine est le vrai domaine de l'entreprise, aucun lien externe ni demande d'identifiants n'est

présent, et le message ne requiert aucune action urgente. Techniquement, ce courriel est **authentique**.

Réponse au RSSI : « légitime ou pas, et qu'est-ce qui fait la différence ? »

Ce courriel est **légitime**. La différence avec l'Incident 1 se lit directement dans les en-têtes, point par point :

Critère	Incident 1 (phishing confirmé)	Incident 7 (ce courriel)
SPF/DKIM/DMARC	Fail / None / Fail	Pass / Pass / Pass
Domaine expéditeur	atlasgrid-it.info (usurpé)	atlasgrid.ma (réel)
Lien	Portail externe de connexion (atlasgrid-it.info/owa/login)	Intranet interne officiel
Action demandée	Ressaisir les identifiants dans l'urgence	Aucune action requise
Outil d'envoi	PHPMailer (envoi de masse externe)	MTA interne d'AtlasGrid
Mise en quarantaine	Oui	Non

Le signalement par 4 utilisateurs n'est donc pas infondé en tant que réflexe (la vigilance post-Incident 1 est saine), mais il constitue ici un **faux positif humain** : le contexte tendu a créé une suspicion sur un message qui, techniquement, ne présente aucun des marqueurs de compromission observés dans l'Incident 1.

Qualification retenue

Verdict : Fausse piste

Justification à inscrire : « En-têtes SPF/DKIM/DMARC tous conformes, domaine et infrastructure d'envoi internes vérifiés (atlasgrid.ma), lien pointant vers l'intranet officiel, aucune demande d'identifiants. Signalement des 4 utilisateurs compréhensible dans le contexte post-phishing (Incident 1) mais non corroboré techniquement. Confirmation du Directeur des SI notée pour mémoire, sans valeur probante en elle-même — le verdict repose ici sur les preuves techniques des en-têtes.

Incident 8 — Inventaire d'impact serveurs (SCCM) — Ampleur du chiffrage confirmé

Date/heure : J2, 10:00 (génération de l'export) — signalé 11:14

Source : Signal technique Service Informatique / SCCM (pièce A-13) — pôle Continuité d'activité

Analyse technique :

- L'inventaire SCCM couvre l'intégralité du parc serveurs (40 machines) et permet de mesurer l'ampleur réelle de l'attaque au-delà du seul poste FIN-112 identifié en Incident 3.
- **23 serveurs sur 40 sont CHIFFRÉS**, confirmant une propagation ransomware à grande échelle et non un incident isolé.
- Serveurs critiques touchés :
 - **PAIE-01** (paie) – chiffré, **paie du mois bloquée** → impact RH/financier direct et immédiat.
 - **FACT-02** (facturation clients) – chiffré, **clôture impossible** → impact financier/comptable direct.
 - **FILER-RBT-02** et **FILER-CASA-01** (partages de fichiers) – chiffrés ; **une note de rançon a été trouvée sur FILER-CASA-01**, ce qui constitue une **preuve matérielle directe** de ransomware (confirmation formelle, au-delà de la détection EDR seule).
 - **ERP-APP-01** et **ERP-DB-01** (application et base de données ERP) – chiffrés → **arrêt probable du système de gestion intégré** de l'entreprise (impact majeur sur l'exploitation).
- Serveurs partiellement affectés :
 - **MSG-01** (messagerie) – fichiers dégradés (partiel).
 - **DC-01** (contrôleur de domaine / Active Directory) – **authentification dégradée** (partiel) → risque élevé, un DC compromis peut indiquer une propagation via les identifiants d'annuaire.
- Serveurs intacts, éléments rassurants :
 - **DC-02** (second contrôleur de domaine) – intact, réplication OK → point de reprise possible pour l'annuaire.
 - **WEB-PUB-01** (site public) – intact, **hors domaine** → probablement épargné car non joint à l'AD, donc hors du chemin de propagation principal.
 - **SCADA-HMI-*** (supervision OT) – intact, **réseau isolé (air-gap)** → la segmentation réseau a fonctionné et a protégé l'environnement industriel/OT.

Corrélation avec les incidents précédents : cet inventaire confirme et quantifie ce qui était pressenti en Incident 2 (vague de tickets multi-services) : la dégradation n'était pas localisée à un seul poste mais bien une propagation large, cohérente avec le mode opératoire identifié en Incident 3 (désactivation EDR, écriture massive de fichiers). La présence physique d'une note de rançon lève toute ambiguïté possible.

Incident 9 – Journal du pare-feu : canal C2 confirmé (règle « OUT-TEMP-443 »)

Date/heure : règle créée J-11, 02:03 – trafic observé J-1, 03:14 à 03:17 (et au-delà) – export demandé et reçu J2 (pièce A-09)

Source : Signal technique Service Informatique / FortiGate (FGT-RBT-01) – pôle SOC/Détection

Analyse technique :

- **Antériorité critique** : la règle de pare-feu « **OUT-TEMP-443** » a été créée le **J-11 à 02:03**, soit **10 jours avant** l'incident ransomware détecté en Incident 3 (J-1). Cela indique une

présence de l'attaquant bien antérieure à l'exécution visible du ransomware, cohérente avec une phase de préparation / persistance (reconnaissance interne, établissement d'un canal de sortie discret avant le déclenchement final).

- Créateur de la règle : **svc_oasisnet** — un compte de service, pas un compte utilisateur nominatif, ce qui est un indicateur fort de compromission (les comptes de service ont souvent des privilèges élevés et sont peu surveillés au quotidien).
- Règle configurée avec **journalisation désactivée** (**journalisation=désactivée**) — technique délibérée pour **minimiser la visibilité** du trafic sortant dans les logs, typique d'un attaquant cherchant à éviter la détection.
- Portée de la règle : **src=FIN-112, dst=any, service=HTTPS** — autorise **tout trafic sortant HTTPS depuis FIN-112 vers n'importe quelle destination**, ce qui est une règle anormalement permissive pour un poste de la Direction Financière.
- Le trafic capturé montre des connexions répétées et régulières de **FIN-112 vers 45.137.184.62:443** — la **même adresse IP** que celle déjà identifiée en Incident 3 (tentative de connexion sortante « contournée »). Cette règle explique techniquement **comment** le blocage a été contourné : le trafic était en réalité **autorisé** par une règle dédiée créée à l'avance.
- Le trafic présente un **pattern de balise (beaconing)** : connexions à intervalle régulier (~60 secondes, avec gigue de 10%), signature caractéristique d'un **canal de commande-et-contrôle (C2)**.
- Volume : **2 118 sessions** vers la même destination sur la période J-1 à J-3, confirmant un canal actif et prolongé, pas une connexion ponctuelle.
- Empreinte JA3 identifiée (**a0e9f5d2b3c1e847f6...**) — signature de négociation TLS pouvant servir à corréler ou détecter ce même outil/malware sur d'autres postes du parc.
- **MITRE ATT&CK : T1071.001 — Application Layer Protocol: Web Protocols (C2 sur HTTPS)**, combiné à **T1562.001** (désactivation de la journalisation, même famille que la désactivation de l'EDR en Incident 3).

Corrélation avec les incidents précédents : cette pièce relie et confirme formellement plusieurs éléments jusque-là partiellement établis : l'IP 45.137.184.62 déjà repérée en Incident 3 est ici confirmée comme un **serveur C2 actif**, et la chronologie révèle que l'attaquant était présent et préparait son infrastructure de sortie **dès J-11**, bien avant le déclenchement du ransomware. Cela remet en question l'hypothèse d'un incident isolé du J-1 et suggère une **intrusion prolongée** avec phase de reconnaissance/préparation.

Résumé :	
Champ	Détail
Nom de l'incident	Canal C2 confirmé via règle pare-feu dédiée (« OUT-TEMP-443 »)
Date	Règle créée J-11, 02:03 — trafic actif J-1 à J-3
Vecteur	Règle pare-feu créée par un compte de service compromis, journalisation désactivée
Impact	Canal de commande-et-contrôle actif ~10 jours, 2 118 sessions, exfiltration/pilotage possible
Verdict	Preuve (règle explicite, IP C2 corrélée à l'Incident 3, pattern de beaconing, T1071.001)

Le journal du pare-feu FortiGate révèle un élément déterminant : une règle nommée « OUT-TEMP-443 » a été créée le J-11 à 02:03 par le compte de service svc_oasisnet, soit dix jours avant le déclenchement visible du ransomware sur FIN-112. Cette règle autorise tout trafic HTTPS sortant depuis FIN-112 vers n'importe quelle destination, et sa journalisation a été volontairement désactivée afin de limiter sa visibilité dans les journaux d'audit. L'analyse du trafic montre des connexions répétées et régulières vers l'adresse IP 45.137.184.62, la même que celle déjà identifiée dans le journal EDR de l'Incident 3, avec un intervalle constant d'environ 60 secondes caractéristique d'un mécanisme de balisage (beaconing) propre à un canal de commande-et-contrôle. Plus de 2 118 sessions ont été recensées vers cette même destination sur la période J-1 à J-3, confirmant un canal actif et prolongé plutôt qu'une connexion ponctuelle. Cette découverte confirme que la connexion sortante « contournée » observée en Incident 3 l'était en réalité grâce à cette règle créée à l'avance, et surtout, elle établit que l'attaquant était présent dans le système bien avant le déclenchement du ransomware, avec une phase de préparation d'au moins dix jours. Cet élément constitue une preuve technique solide, correspondant à la technique T1071.001 du référentiel MITRE ATT&CK.

Incident 10 — Exfiltration massive de données confirmée (journal proxy Zscaler)

Date/heure : transferts observés sur 10 nuits, J-10 à J-1 (créneaux 02h00–05h00) — export généré J2, 09:30 (pièce A-03)

Source : Signal technique Service Informatique / Zscaler NSS (proxy web) — pôle SOC/Détection

Analyse technique :

- Le journal proxy confirme et **quantifie** ce que le journal pare-feu (Incident 9) avait révélé comme canal C2 : il ne s'agissait pas seulement de balisage, mais d'un **volume de données réellement transféré**, massif et soutenu.

- **Antériorité encore plus longue** : les transferts commencent dès **J-10**, ce qui élargit encore la fenêtre de présence de l'attaquant (déjà estimée à J-11 avec la création de la règle pare-feu en Incident 9). L'intrusion est donc active depuis **au moins 10 à 11 jours** avant la détection du ransomware.
- **Destination identique** sur toute la période : **45.137.184.62:443** — la même IP que le canal C2 (Incident 9) et que la tentative de connexion bloquée/contournée (Incident 3). Ce recoupement sur trois pièces distinctes **élimine toute ambiguïté** sur le rôle de cette IP.
- **Progression des sources dans le temps**, cohérente avec la chronologie d'attaque :
 - J-10 et J-9 : source **FIN-112** (poste initialement compromis, cf. Incident 3) — 11,2 Go puis 12,8 Go.
 - J-8 à J-1 : source **FILER-RBT** (serveur de partage de fichiers, l'un des serveurs chiffrés identifiés en Incident 8) — l'attaquant a **pivoté** du poste initial vers un serveur de fichiers à plus fort volume de données, signe d'un **mouvement latéral** délibéré pour maximiser la collecte avant chiffrement.
- **Volume total** : **117,8 Go** exfiltrés sur 10 nuits, à raison de 9 à 14 Go par nuit — un volume incompatible avec un usage légitime et cohérent avec une exfiltration organisée de données d'entreprise.
- **Horaires systématiquement nocturnes** (02h00–05h00), en dehors des heures de bureau, afin de **minimiser la détection humaine** et se fondre dans un trafic réseau globalement plus faible.
- **SNI suspect** : **cdn-sync-eu.storage-blob[.]net** — nom de domaine imitant un service cloud légitime (type CDN/stockage blob) pour se fondre dans du trafic normal ; catégorisé « **Non classée** » par le proxy, ce qui explique pourquoi il n'a pas été bloqué automatiquement.
- **JA3 identique** à celui relevé en Incident 9 (**a0e9f5d2b3c1e847f6...**) — confirmation formelle qu'il s'agit du **même outil/implant malveillant** pilotant à la fois le C2 et l'exfiltration.
- Le proxy lui-même qualifie ce trafic de « **classe_menace = exfiltration de données (suspectée)** ».
- **MITRE ATT&CK : T1041 — Exfiltration Over C2 Channel**, en complément de T1071.001 (Incident 9).

Corrélation avec les incidents précédents : cette pièce est la **confirmation finale** de la chaîne d'attaque complète : compromission initiale via phishing (Incident 1) → accès à FIN-112 → établissement d'un canal C2 discret dès J-11 (Incident 9) → exfiltration démarrant J-10 depuis FIN-112 puis pivot vers FILER-RBT pour un volume plus important → chiffrement final des 23 serveurs (Incident 8) une fois la collecte de données jugée suffisante par l'attaquant. Le schéma correspond à un mode opératoire classique de **double extorsion** (exfiltration puis chiffrement).

Résumé :

Champ	Détail
Nom de l'incident	Exfiltration massive de données vers IP C2 externe (journal proxy Zscaler)
Date	J-10 à J-1, créneaux nocturnes 02h-05h
Vecteur	Canal HTTPS chiffré vers domaine imitant un service cloud légitime
Impact	117,8 Go de données exfiltrées depuis FIN-112 puis FILER-RBT — probable double extorsion
Verdict	Preuve (volume mesuré, IP/JA3 corrélés aux Incidents 3 et 9, T1041)

Le journal des transferts sortants du proxy Zscaler confirme et quantifie une exfiltration massive de données. Sur dix nuits consécutives, de J-10 à J-1, entre 02h00 et 05h00 du matin, un total de 117,8 Go de données a été transféré vers l'adresse IP 45.137.184.62, la même que celle déjà identifiée comme canal de commande-et-contrôle dans le journal du pare-feu et dans le journal EDR. Les deux premières nuits, la source de ces transferts était le poste FIN-112, initialement compromis ; à partir de J-8, la source bascule vers le serveur de partage de fichiers FILER-RBT, l'un des serveurs chiffrés identifiés dans l'inventaire d'impact, ce qui indique un mouvement latéral de l'attaquant vers une source de données plus volumineuse. Les transferts ont systématiquement eu lieu en dehors des heures de bureau afin de limiter les risques de détection, et le nom de domaine utilisé (cdn-sync-eu.storage-blob.net) imite un service cloud légitime pour se fondre dans le trafic normal, ce qui explique qu'il n'ait pas été bloqué automatiquement. L'empreinte JA3 relevée est identique à celle du canal C2 déjà documenté, confirmant qu'il s'agit du même outil malveillant. Cette pièce établit la présence de l'attaquant dès J-10, en cohérence avec la création de la règle pare-feu dix jours avant l'incident, et complète la reconstitution de la chaîne d'attaque : compromission initiale, établissement d'un canal C2 discret, exfiltration progressive des données, puis chiffrement final des serveurs — un scénario cohérent avec une attaque de type double extorsion.

Incident 11 — Chronologie EDR détaillée du chiffrement (poste FIN-112) — Mode opératoire complet

Date/heure : J-1, 03:12:09 à 03:15:40 (chronologie sur ~3 minutes) — export généré J2, 09:20 (pièce A-12)

Source : Signal technique Service Informatique / Microsoft Defender for Endpoint (device timeline) — pôle SOC/Détection et Forensic

cette chronologie est la pièce la plus complète du dossier car elle reconstitue **le mode opératoire exact de l'attaquant en 3 minutes et 31 secondes**, de l'exécution initiale à la destruction méthodique des moyens de récupération :

1. **Exécution** du ransomware déguisé en processus système (03:12:09)
2. **Neutralisation** de la défense (03:12:41)
3. **Reconnaissance** des fichiers cibles (03:13:02)
4. **Communication C2** (03:14:31)

5. **Chiffrement** effectif sur 14 partages (03:15:03)
6. **Sabotage méthodique et systématique de toutes les voies de récupération** : clichés instantanés, options de démarrage, catalogue de sauvegarde (03:15:07–09) — cette séquence de trois commandes en 2 secondes démontre un **script automatisé**, pas une action manuelle
7. **Arrêt forcé** de l'antivirus restant actif (03:15:22)
8. **Dépôt de la demande de rançon** sur chaque partage touché (03:15:40)

Cette séquence correspond très précisément à la technique **MITRE ATT&CK T1486 (Data Encrypted for Impact)**, combinée à **T1490 (Inhibit System Recovery)** pour la suppression des shadow copies, catalogues de sauvegarde et options de récupération — un ensemble d'actions délibérées visant à **rendre toute restauration native impossible**, maximisant la pression pour le paiement de la rançon.

Corrélation avec les incidents précédents : cette pièce relie explicitement tous les éléments forensiques déjà collectés — le fichier et le SHA256 de l'Incident 3, l'IP C2 des Incidents 9 et 10, le nombre de serveurs/partages chiffrés de l'Incident 8, et la note de rançon physique déjà trouvée. Elle constitue la **preuve technique la plus détaillée et la plus complète** de l'ensemble du dossier.

La chronologie détaillée extraite de Microsoft Defender for Endpoint reconstitue avec précision le mode opératoire de l'attaquant sur le poste FIN-112, entre 03:12:09 et 03:15:40, soit une durée totale de seulement trois minutes et trente et une secondes. Le processus malveillant svhost32.exe est d'abord exécuté, puis la protection en temps réel est désactivée directement via une modification de la base de registre. L'attaquant procède ensuite à la lecture de 9 412 fichiers bureautiques et techniques, en vue de leur chiffrement, avant d'établir une connexion réseau vers l'adresse IP 45.137.184.62, confirmant le canal de commande-et-contrôle déjà identifié dans le journal du pare-feu et le journal du proxy. Le chiffrement s'opère ensuite sur quatorze partages réseau, expliquant techniquement la vague de tickets remontée par plusieurs services de l'entreprise. Dans la foulée, une série de trois commandes exécutées en seulement deux secondes supprime les clichés instantanés du système, désactive les options de récupération au démarrage et efface le catalogue des sauvegardes Windows, rendant toute restauration native impossible ; l'enchaînement rapide et systématique de ces commandes indique un script automatisé plutôt qu'une intervention manuelle. L'antivirus encore actif est ensuite arrêté de force, et une note de rançon est déposée sur chacun des quatorze partages touchés. Cette chronologie constitue la preuve technique la plus complète du dossier, reliant l'ensemble des éléments déjà collectés dans les incidents précédents et confirmant sans ambiguïté qu'il s'agit d'une attaque par ransomware délibérée, structurée et automatisée, correspondant aux techniques MITRE ATT&CK T1486 et T1490.

Incident 12 — Alerte EDR sur outil d'administration (PsExec) — Faux positif

Date/heure : J1, 10:12 — signalé 12:36

Source : Signal technique Service Informatique / EDR, file d'alertes (pièce A-25)

Analyse technique :

- L'alerte **HackTool:Win32/PsExec** est un déclenchement générique et fréquent : PsExec est un **outil légitime de Microsoft Sysinternals**, largement utilisé par les administrateurs pour l'exécution à distance, mais aussi fréquemment détourné par des attaquants (d'où la détection par catégorie « HackTool » plutôt qu'un signal de malveillance confirmée).
- **Éditeur et signature** : le fichier **C:\Tools\PsExec.exe** est **signé numériquement par Microsoft Corporation (Sysinternals)**, et son SHA256 **correspond exactement à la version officielle** — aucune altération, aucun remplacement par un binaire malveillant déguisé (contrairement au cas **svhost32.exe** de l'Incident 3/11).
- **Acteur** : **admin_it**, sur une **session nominative** (pas un compte de service anonyme comme **svc_oasisnet** en Incident 9, ni un compte générique comme **admin_local** en Incident 3) — traçabilité claire et cohérente avec une identité légitime.
- **Horaire** : 10:12, en **heures ouvrées** — à l'opposé des créneaux nocturnes (02h–05h) systématiquement utilisés par l'attaquant dans les Incidents 3, 9, 10 et 11.
- **Ticket associé** : **#4502**, maintenance à distance **planifiée** — traçabilité administrative complète, contrairement aux actions de l'attaquant qui n'ont laissé aucune trace de changement légitime.
- **Absence totale d'indicateurs de compromission** : aucun renommage en **.mirage**, aucun flux réseau vers 45.137.x.x (l'IP C2 identifiée dans les Incidents 3, 9 et 10) — élément déterminant qui écarte tout lien avec la chaîne d'attaque principale.

Corrélation avec les incidents précédents : cette alerte ne présente **aucun des marqueurs** identifiés dans la chaîne d'attaque réelle (pas de binaire non signé, pas d'horaire nocturne, pas de compte de service compromis, pas de connexion vers l'IP C2, pas de chiffrement). Il s'agit d'un cas d'école de **faux positif** généré par la détection générique d'un outil d'administration légitime utilisé dans son contexte normal.